CheckIn

Daily Work Report — Database & Backend

Student Attendance System · IDE201 Capstone · Group 2 · College of Science and Technology

Contributor	Ugyen Norbu (GitHub: UgayNobu)
Role	Database manager; backend; repository owner
Date	Tuesday, 13 October 2026
Repository	github.com/UgayNobu/Checkin (branch: dev)
Pull requests	#23 and #25 (both merged into dev)

1. Summary

Today I made sign-up and login properly validated and added a forgot-password feature, removed an unnecessary field from the admin module form, cleaned up the test tutor's module assignments in the database, and fixed evidence documents so that management and tutors can open the files students upload. Two new database tables were added, both through our single database.sql file and run on Supabase.

Work that belongs to teammates (Sanjuck's and Sanskar's pull requests, which I only reviewed and merged) is listed in Section 6 and is not counted here.

3	2	2	3	26
commits	pull requests merged	database tables added	API routes added	files changed

2. Work completed

2.1 Admin module form (PR #23)

- **Removed "Number of Modules":** the field had no use in the admin's Add / Edit Module form, so I removed it from the form and its state. The database column was left in place so no data is lost.

2.2 Sign-up and login validation (PR #23)

Before, the only rule was "at least 8 characters". Now every field is checked in the browser and checked again on the server (zod validators), so the rules cannot be bypassed.

Field	Rule
Student ID	Exactly 8 digits, e.g. 02250368
Staff ID	CST- followed by 2–6 letters or digits, e.g. CST-0142

Field	Rule
Email	Must be a college email ending in @rub.edu.bt; one account per email (not case-sensitive)
Full name	Letters only; spaces, dots, hyphens and apostrophes allowed
Programme / department	Required for students / tutors
Password	8–64 characters, upper case, lower case, a number, a symbol, no spaces
Confirm password	Must match

- **Clear feedback:** a red message appears under the exact field that is wrong, and a live checklist ticks off each password rule while typing.
- **Easier to use:** a “Show password” option and a busy state on the buttons, so a form can’t be sent twice.
- **Same rule everywhere:** the change-password screens for students and tutors use the same password rule.
- **Login:** checks that both boxes are filled and links to the new Forgot password page. Existing test IDs such as U004 still work.

2.3 Forgot password (PR #23)

A three-step page: enter your ID → enter the 6-digit code sent to your college email → choose a new password.

- **Secure code:** a random 6-digit code is created with Node’s crypto module. Only a bcrypt hash of the code is stored, never the code itself.
- **Limits:** a code works once, expires after 15 minutes, and is blocked after 5 wrong tries. Asking for a new code cancels the old one. The two routes are rate-limited to 10 requests per 15 minutes.
- **No account guessing:** the page always gives the same message, so it does not reveal whether an ID exists.
- **Delivery:** the code is emailed when Gmail SMTP is configured; during development it is printed in the backend terminal instead.
- **Safe update:** the new password and the “code used” mark are saved in one transaction, and the user gets a notification that their password changed.
- **New routes:** POST /api/auth/forgot-password and POST /api/auth/reset-password, documented in API.md.

2.4 Tutor module clean-up (database)

- **Problem:** the test tutor (CST-0142) showed 7 modules, because old sample modules had been moved to that account when we reduced the database to 4 users.
- **Fix:** wrote SQL that keeps only IDE202 (Software Engineering Internship I) for this tutor. It deletes the other sections and their class sessions and attendance in foreign-key order. Modules, enrolments and evidence were not touched.
- **Safety:** ran a preview query first and tested the script on a local copy of the database before running it on Supabase. When the Supabase editor did not keep a temporary table between statements, I rewrote the script as plain DELETE statements.

2.5 Evidence documents can now be opened (PR #25)

Students could submit evidence, but management and tutors could not open the document. I found two causes:

- Each file was saved in the backend/uploads folder of whichever laptop was running the student's backend, so other laptops had no copy.
- The backend's security headers stopped the frontend (a different port) from showing a PDF inside the page.
- **Fix — files in the database:** uploads are now saved in a new stored_files table, so every teammate's backend and the future deployed server can open the same file.
- **New route:** GET /api/files/:id serves the file and allows the CheckIn frontend to display it. The id is a random UUID that the API only gives to people allowed to see the request.
- **Viewer:** the Evidence page now shows images and PDFs on the page, uses the real file name, and has an "Open in a new tab" button.
- **Old data:** removed 9 old evidence rows whose files only existed on one laptop, after checking them with a preview query.

2.6 Team testing

- **Test plan:** prepared a step-by-step plan for the team to test the whole system with the 4 accounts: admin assigns a tutor → tutor sets a key → student enrols → check-in → evidence → management approval.
- **Keeping everyone up to date:** helped teammates pull the latest dev branch and regenerate the Prisma client.

3. Database changes today

Table	Purpose	Key rules
password_resets	One row per forgot-password request	Stores a bcrypt hash only; expiry must be after creation; attempts ≥ 0; deleted with the user (ON DELETE CASCADE); index on (user_id, created_at); row-level security on
stored_files	Uploaded evidence documents and profile photos	UUID primary key; file kept as BYTEA; max 10 MB; only PDF, PNG, JPG and WebP; deleted with the owner; index on owner_id; row-level security on

Both tables were added as Part 7 and Part 8 of backend/prisma/database.sql, which is safe to re-run, and to schema.prisma. Following our rule, no prisma migrate or db push was used on the shared database.

4. How the work was tested

- Every SQL script was run first on a local PostgreSQL copy of our Supabase database, then on Supabase.
- Sign-up, login and forgot password: tested wrong inputs on each field and the full reset flow from code to new password.

- Evidence: uploaded a PDF and an image as the student, then opened both in a browser as management and as the tutor. The downloaded file matched the uploaded one byte for byte, and no frame or security errors appeared.
- Checked on Supabase afterwards: the tutor has only IDE202, and no evidence rows point at old laptop files.

5. Good practices followed

- No secrets were committed; .env.example only explains how to set up Gmail SMTP with placeholders.
- Every delete was previewed first and limited to test data.
- Each change went through a feature branch and a pull request into dev.
- Rules are checked on both the frontend and the backend.

6. Not counted as my contribution

I reviewed and merged the following today, but the work belongs to my teammates:

- **Sanjuck (PR #22):** the admin “Add New Program” bar and the management overview. I only resolved the merge with dev.
- **Sanskar (PR #24):** evidence rules — one request per day, visible to all of the student’s tutors, management-only approval, and the cookie login fix.

7. Next steps

- Finish the full system test with the team and fix anything that breaks.
- Remove the extra test accounts and the old sample modules so only real curriculum data and the 4 accounts remain.
- Add real classroom coordinates and agree on a geofence radius for check-in.
- Set up Gmail SMTP so reset codes reach the user’s inbox.
- Update the ERD and my database notes with password_resets and stored_files.

Appendix: My commits today

Time	PR	Commit	Description
14:39	#23	390d6e8	Admin module form: remove the Number of Modules field
14:50	#23	5a53232	Proper sign-up / login validation and a forgot-password flow
15:42	#25	0920a09	Evidence: save uploaded files in the database so every laptop can open them